

Threat Modelling for Cyber-Physical Systems

Abinel Madzivire

1. Key elements and interdependencies that must be captured in a comprehensive CPS threat model

Cyber-physical systems (CPS) integrate computational, communication and physical components, making their security fundamentally different from that of conventional information technology systems. Jbair et al. (2022) emphasise that threat modelling for industrial CPS must account for the interaction between cyber and physical domains rather than analysing individual components in isolation. A comprehensive threat model should therefore capture physical assets, computational components, communication networks, control systems, human actors, software, data flows and external interfaces.

Physical assets include sensors, actuators, industrial machinery, generators and other operational technology (OT). Computational components include programmable logic controllers (PLCs), supervisory control and data acquisition (SCADA) systems, engineering workstations and industrial servers. Communication infrastructure is equally important because protocols, gateways, wireless connections and remote-access mechanisms can provide pathways through which an attacker moves between otherwise separate system components.

The interdependencies between these elements are particularly critical. A compromised sensor, for example, may transmit manipulated information to a controller, causing the controller to issue an unsafe command to an actuator. Consequently, a relatively minor cyber compromise can produce significant physical consequences, including equipment damage, production disruption or threats to

human safety. Similarly, a compromised remote-access account may provide an attacker with access to several interconnected OT systems.

Accurate risk analysis therefore requires understanding assets, trust relationships, dependencies, data flows, system boundaries and potential consequences. Failing to model these relationships can result in vulnerabilities being assessed independently when their combination creates a much greater systemic risk. This supports Jbair et al.'s (2022) argument that CPS threat modelling should reflect the complex interactions between cyber and physical environments.

2. Threat modelling, attack entry points and vulnerabilities in cyber-physical energy systems

Threat modelling provides a structured method for identifying how an attacker could enter, move through and ultimately compromise a cyber-physical energy system. The process begins by mapping the system architecture and identifying attack surfaces. These may include internet-connected devices, remote-access services, corporate-to-OT connections, wireless networks, third-party interfaces, poorly secured protocols, removable media and compromised user credentials.

Techniques such as attack trees, data-flow diagrams, STRIDE, attack graphs and threat-oriented risk assessments can subsequently be used to examine possible attack paths. For example, an attacker could compromise an internet-facing corporate system, obtain valid credentials, move laterally towards an operational network and eventually manipulate a PLC or SCADA component. Threat modelling therefore helps security practitioners understand not only whether an individual vulnerability exists but also how that vulnerability could be exploited within the wider system.

In energy systems, this is particularly important because cyber-attacks can have physical consequences. Manipulation of protection systems, sensors or control commands could potentially cause equipment failure, service disruption or instability within the energy network. Consequently, vulnerability assessment should consider both traditional cybersecurity properties such as confidentiality, integrity and availability and CPS-specific concerns such as physical safety, reliability, resilience and operational continuity.

However, effective threat modelling presents several challenges. Industrial environments frequently contain legacy technologies, proprietary protocols and heterogeneous devices, some of which were not originally designed with modern cybersecurity requirements in mind. In addition, complete system architectures and dependencies may be difficult to document. Threat models can also become outdated as systems are modified, new devices are connected and emerging technologies such as IoT and cloud services are introduced.

Another challenge is the tension between cybersecurity and operational requirements. Security controls that are relatively straightforward to implement in IT environments may be unsuitable for critical infrastructure where availability and safety take precedence. Threat modelling must therefore avoid recommending countermeasures that could themselves disrupt essential operations.

3. Scenario-specific metrics and risk assessment for prioritising vulnerabilities

A major strength of CPS threat modelling is that vulnerabilities can be prioritised according to the specific operational scenario and potential consequences, rather than simply according to technical severity. Jbair et al. (2022) demonstrate the importance of contextualising threats within industrial environments. A vulnerability affecting a non-

critical workstation, for example, may present considerably less risk than the same vulnerability affecting a safety-critical controller.

Scenario-specific metrics can include likelihood of exploitation, attack complexity, exposure, exploitability, asset criticality, potential physical impact, safety consequences, operational disruption, financial loss and recovery requirements. These measures can be combined to develop a risk score, enabling organisations to distinguish high-priority vulnerabilities from lower-risk weaknesses.

Risk assessment methodologies such as CVSS, attack-tree analysis, attack graphs, risk matrices and established cybersecurity frameworks can support this prioritisation. However, conventional IT metrics should not be used in isolation. A vulnerability with a moderate CVSS score could represent a critical CPS risk if exploitation could manipulate a physical process or compromise human safety. Consequently, CPS-specific assessments should incorporate both cybersecurity severity and physical/operational consequences.

The resulting risk ranking can guide targeted security countermeasures. High-risk attack paths may require network segmentation, stronger authentication, privileged-access management, secure remote access, application allow-listing, intrusion detection, continuous monitoring or improved incident-response procedures. Lower-risk vulnerabilities may be addressed through routine patching or longer-term system upgrades.

Importantly, threat modelling should be treated as a continuous process rather than a one-off assessment. Changes to system architecture, new vulnerabilities, emerging threats and changes in operational conditions can alter the risk profile. Continuous

reassessment allows security controls to remain aligned with the actual threat environment.

Overall, Jbair et al. (2022) demonstrate that effective CPS threat modelling requires a holistic understanding of the relationship between cyber components, physical processes and operational objectives. By combining system interdependency analysis, attack-path identification and scenario-specific risk metrics, organisations can move beyond simply cataloguing vulnerabilities towards prioritised, risk-informed and targeted security decisions. This is particularly important in energy and smart-manufacturing environments, where cyber incidents can propagate into the physical world and potentially affect safety, availability and critical services.

Reference

Jbair, M., Ahmad, B., Maple, C. and Harrison, R. (2022) 'Threat modelling for industrial cyber physical systems in the era of smart manufacturing', *Computers in Industry*, 137, p.103611.